ZEDPATH

Team Kestrel · IntelliCon '26 Buildathon

ZP-DOC-08

Test Summary Report

Executed results of the automated suites and the agent test harnesses, 11 to 12 October 2026, with the security audit run-1 and the update of 15 October 2026

Version	0.9
Status	In review
Date	15 October 2026
Classification	Public
Document owner	B.M.P Banneka, Product Owner

© 2026 Team Kestrel. Published under the classification shown above.

Uncontrolled when printed or exported. The controlled version is the Markdown source in the repository: docs/08-test-plan/ZP-DOC-08_Test-Summary-Report.md

Document control

Document information

Document ID	ZP-DOC-08
Title	Test Summary Report
Version	0.9
Status	In review
Classification	Public
Document owner	B.M.P Banneka, Product Owner
Author	Team Kestrel (drafted with Claude, AI coding partner)
Conforms to	IEEE 829 / ISO/IEC/IEEE 29119-3 test summary report; ZP-DOC-00
Source file	docs/08-test-plan/ZP-DOC-08_Test-Summary-Report.md
Repository	https://github.com/PraveenBanneka/zedpath

Revision history

Version	Date	Author	Description of change
0.9	12 Oct 2026	Team Kestrel	First issue: results of the 20-agent test campaign (1,053 executed cases), defects found, open risks; companion to the ZP-DOC-08 Test Plan; submitted for approval
0.9	15 Oct 2026	Team Kestrel	Revised in review: status of the findings updated (D-03, D-04, D-05, D-10 and D-12 fixed; D-08 http link fixed, Google Drive mirror still open); new section on security audit run-1 (method; 0 confirmed, 17 needs-validation, 1 rejected; each lead with its fix and test; lead 9 accepted); automated suite re-run on 15 October 2026 (532 passed, 0 expected-fail, 21 opt-in)

Review and approval

This document takes effect when the approver signs below. Until then its status is as shown on the cover.

Role	Name	Signature	Date
Reviewer	Claude (AI coding partner), consistency and traceability review		
Approver	B.M.P Banneka, Product Owner		

Contents

1 Introduction 4
1.1 Purpose 4
1.2 How the campaign was run 4
1.3 Test environments 4
2 Results summary 5
2.1 Totals 5
2.2 Re-run of 15 October 2026 5
2.3 What the campaign proves 6
3 Defects and findings 7
3.1 Failures that are not application defects 8
4 Security audit run-1 9
4.1 Method 9
4.2 Results 9
5 Limits of this campaign 11
6 Conclusion 12
7 Appendix A. Result files 13

List of tables

Table 1: Test environments 4
Table 2: Executed cases by suite 5
Table 3: Automated suite on 15 October 2026 (commit f704d0b) 5
Table 4: What the campaign proves 6
Table 5: Defects and findings 7
Table 6: Failures that are not application defects 8
Table 7: Security audit run-1 results 9
Table 8: Security audit run-1 leads, fixes and tests 9

1 Introduction

1.1 Purpose

This report records what was actually executed against ZedPath on 11 and 12 October 2026, what passed, what failed and why. It is the companion of the ZP-DOC-08 Test Plan, which sets the strategy, environments and Definition of Done. Every number below comes from a result file committed in the repository; nothing is estimated.

1.2 How the campaign was run

The product owner asked for an independent, documented test campaign of more than 200 cases within two hours. It was run as an **agent harness**: the main session split the work into 20 independent agents, each with one test area, a written brief, safety rules and an output file. Each agent wrote its own test code, ran it, and reported its results; the main session reviewed each report, committed the code and the results, and wrote this summary. No agent was allowed to change application code, so every failure below is reported as found.

Safety rules applied to every agent: no deploys; no production writes except where stated; test accounts deleted at the end and checked (login afterwards returns 401); no new groups created and no chat messages posted on shared data; no question sent to the AI model (quota); nothing fetched from outside the allow-list.

1.3 Test environments

Table 1: Test environments

Environment	Used for
Vitest on Node, with the real D1 migrations in SQLite (worker/testing/d1-sqlite.ts)	Unit, integration, data and schema suites
Local Worker (wrangler dev --local)	API, security, browser, accessibility, offline and layout harnesses
Live production Worker, read-only	Live API and live static/PWA/security checks (GET requests and requests refused before any write)
agent-browser (Chrome) at 390 x 844 and five other viewports	Browser, accessibility, offline and layout harnesses

2 Results summary

2.1 Totals

Table 2: Executed cases by suite

Suite	Target	Cases	Passed	Failed	Skipped	Result file
Automated test suite (vitest, 30+ files incl. the new e2e suites; 12 October)	Code + SQLite D1	515	494	0	21	npx vitest run
Worker CPU budget (opt-in, PERF=1)	Code	21	21 on CPU mean	wall time noisy	0	tools/e2e/results/perf.md
API end-to-end harness	Local Worker	218	211	7	10	tools/e2e/results/api-results.md
Browser end-to-end harness	Local Worker	42	42	0	0	tools/e2e/results/ui-results.md
Security harness	Local Worker	56	53	3	0	tools/e2e/results/security.md
Group chat WebSocket check	Local Worker	8	8	0	0	tools/e2e/results/groups.md
Offline app (PWA)	Local Worker	21	20	1	0	tools/e2e/results/pwa.md
Accessibility and languages	Local Worker	36	22	14	0	tools/e2e/results/a11y-i18n.md
Responsive layout (6 viewports)	Local Worker	33	31	2	0	tools/e2e/results/responsive.md
Live API, read-only	Production	86	85	1	0	tools/e2e/results/live-readonly.md
Live static, PWA and security, read-only	Production	38	35	3	0	tools/e2e/results/live-static.md
Total executed		**1,053** (excl. 21 skipped)				

The vitest figure counts intentional "expected fail" tests (known gaps written as the behaviour we want) as passing: 5 in the group contact filter and 1 in list storage. They start failing as soon as the gap is fixed, which forces the test to be switched to a normal one. *Update (15 October 2026):* both gaps were fixed (D-04, D-12) and all six are now normal tests; no expected-fail test remains.

Type check: `npx tsc -b` clean. Leak scan of the full history: clean. Deploy-guard tests: 35 of 40 (see D-10); 40 of 40 since 14 October 2026.

2.2 Re-run of 15 October 2026

Table 3: Automated suite on 15 October 2026 (commit f704d0b)

Check	Result
`npx vitest run`	34 files (33 passed, 1 opt-in skipped); 553 tests: **532 passed, 0 failed, 0 expected-fail, 21 skipped** (the opt-in CPU budget, run with `PERF=1`)

Check	Result
New test files since 12 October	`worker/demo-login.test.ts` (9), `worker/demo-data.test.ts` (1), `worker/statistics.test.ts` (5), `worker/aptitude.test.ts` (5), `worker/session-kick.test.ts` (5), `worker/hardening.test.ts` (7), `src/owner.test.ts` (2); grown: `src/demo.test.ts` (2 to 4), `worker/groups.test.ts` (16 to 17), `worker/data-integrity.e2e.test.ts` (DAT-054 added)
`npx tsc -b`	Exit code 0
`bash .claude/hooks/test-guard.sh`	40 passed, 0 failed

2.3 What the campaign proves

Table 4: What the campaign proves

Area	Evidence
Course rules and cut-offs match the official UGC data	75 accuracy cases against the UGC CSVs, independent of the app's own loader: 255 Uni-Codes, 5,650 cut-off cells (2025/26) and 6,175 (2024/25) equal, zero banding differences over a full grid; a higher Z-score never lowers a band
Rules are enforced on the server, not only hidden in the UI	API harness: early Journey ticks refused (409), invalid avatars refused (400), 21 private routes refuse requests without a session (401), cross-site writes refused (403)
One student cannot reach another's data	Security harness: journey, avatar, contact, membership, reports and blocks tried across accounts; the account comes only from the session cookie
Deleting an account deletes everything	Database suite: cascade to all 15 child tables; API harness: no orphan rows after cleanup
The 0010 migration is safe to roll back	Database suite: the previous release's SQL runs on the new schema (expand, then contract)
Every published fact has an official source	Data suite: all links https on allow-listed official domains (two exceptions, D-08), every number with a page and quote, no invented UGC dates
Group chat keeps students safe	Phone numbers and emails refused by the live room (WebSocket check 8/8); sample chats labelled; rules asked once per account
Ask ZedPath does not leak model reasoning and cites sources	46 offline cases with a fake model: leaked reasoning rejected, next model tried, links restricted to https
The app works on real phones and languages	Browser harness 42/42 end to end; English fits at all six viewports; html lang follows the chosen language
The free plan holds	Average CPU per request within 10 ms for every route (heaviest results profile 7 to 10 ms)

3 Defects and findings

Severity: High = wrong result or data exposure; Medium = visible to students or a security weakness without data exposure; Low = cosmetic, performance or tooling. None of the findings exposes data or gives a wrong course result.

Table 5: Defects and findings

ID	Finding	Severity	Found by	Status
D-01	Tamil Courses screen scrolls sideways at normal phone width (Safe/Likely/Reach tabs do not fit); Sinhala at 320 px too	Medium	Accessibility, layout	Open
D-02	Grey helper text and green status pills below WCAG AA contrast (3.0 to 3.8 against 4.5)	Medium	Accessibility	Open
D-03	A malformed or "null" Origin header returns 500 instead of 403 (nothing is written)	Low	Security	**Fixed 15 Oct 2026**: `crossSite()` treats an unparsable Origin as cross-site (403), shared by every write route and Ask; tests in `worker/demo-login.test.ts` and `worker/session-kick.test.ts`; live-checked on 59ad7760 (Origin "null" 403)
D-04	Group contact filter misses some formats: 0094..., (077) 123 4567, spelled-out numbers, chat.whatsapp.com invites	Medium	Group chat, security	**Fixed 15 Oct 2026** (audit lead 16): the filter also checks a normalised copy; GRP-012 to GRP-016 in `worker/groups.e2e.test.ts` are now normal passing tests
D-05	Weak ETag from compression never matches, so the API never answers 304 (extra data on 3G)	Low	Live API	**Fixed 15 Oct 2026**: the `W/` prefix is stripped before comparing; test in `worker/statistics.test.ts`
D-06	No security headers (HSTS, nosniff, CSP, frame options) and no http to https redirect on workers.dev	Medium	Live API, live static	Open; _headers file plus middleware
D-07	Hashed JS/CSS not long-cached; first visit does not precache them for offline use	Low	Live static, PWA	Open
D-08	One route link uses http; one syllabus source is a Google Drive mirror, not the university's site	Low	Data	**http link fixed 14 Oct 2026** (route R027 now uses the institute's own https site; live on 926c9217). The Google Drive mirror is still open, pinned in the data suite
D-09	Some touch targets under 44 px (Me avatar, tabs, intro dots)	Low	Accessibility	Open
D-10	Deploy-guard tests still expect the old repo name (5 of 40 fail, all over-blocking)	Low	Test plan, security	**Fixed 14 Oct 2026**: test file updated with the guard; 40 of 40 pass
D-11	Some university names show cut off ("Sabaragamuwa University of"); "1 courses" wording	Low	Browser, layout	Open

ID	Finding	Severity	Found by	Status
D-12	List storage accepts valid JSON of the wrong shape	Low	List suite	**Fixed 15 Oct 2026**: anything that is not a list reads as an empty list; LST-036 in `shared/list.e2e.test.ts` is now a normal test
D-13	ZP-DOC-05 omits ask_quota and four indexes; one privacy sentence predates CR-003	Low (documentation)	Database suite	Open

3.1 Failures that are not application defects

Table 6: Failures that are not application defects

Suite	Cases	Cause
API harness	7	The local development proxy drops about one in three requests whose body the Worker does not read before an early refusal; each case gives the right answer when sent alone. To be confirmed on production.
CPU budget	wall-time p95	Measured on a laptop running 20 agents at once; CPU time per request stayed within budget

4 Security audit run-1

4.1 Method

On 15 October 2026 the Cloudflare security-audit skill (kept locally, outside the repository) was run against the whole repository by 37 agents. The agents reported *leads*: possible weaknesses, each with the code that would cause it. A lead is **confirmed** only when the weakness is proven by running it; no sandbox was available on the developer machine, so no lead could be confirmed, and the audit itself rejected one lead. The main session read every remaining lead against the code and fixed it, with a test wherever the behaviour can be tested outside a browser or a Durable Object. The full report stays outside the public repository, so the table below describes each lead only at the level needed to understand its fix.

4.2 Results

Table 7: Security audit run-1 results

Outcome	Leads
Confirmed	0 (no sandbox to prove exploitation)
Needs validation	17
Rejected	1

Table 8: Security audit run-1 leads, fixes and tests

Lead	Weakness	Fix (15 October 2026)	Test
1, 5	The public demo password was in the code and the demo script and was prefilled at sign-up; the demo flag survived clearing the phone	Password removed and never prefilled; clearing the phone clears demo mode	`src/demo.test.ts`
2	A group chat stayed open on a device after log-out, log out everywhere, recovery or leaving	`kickFromRooms()` closes the sockets of that session, account or group	`worker/session-kick.test.ts`
3	Deleting an account purged messages only from groups it was still in	`group_room_seen` (migration 0012, ZP-DOC-05) records every room opened; deletion purges all of them	`worker/session-kick.test.ts`
4	A few fresh accounts could hide any message by reporting it	Reports from accounts under a day old or demo accounts are recorded but do not count	`worker/groups.test.ts`
6	A failed log-out was ignored and shown as success	The failure is reported; the student stays logged in	Manual check (client)
7	The next student on a shared phone inherited the previous student's local data	Local data tagged with its owner and cleared when another student logs in	`src/owner.test.ts`
8	No limit on writes by a signed-in account	100 data-changing requests a minute per account	`worker/hardening.test.ts`

Lead	Weakness	Fix (15 October 2026)	Test
9	The log-in limit is keyed per username, which the caller chooses	**Accepted risk, not changed**: tightening it per network would lock out a school laboratory sharing one address; the network-wide limit of 100 a minute stays; a Turnstile human check is planned	`worker/account.test.ts` ("a whole class behind one school IP")
10	Answer feedback could grow without bound	2,000 a day for the service; rows older than a year deleted	`worker/hardening.test.ts`
11	Demo accounts could be created without bound; clean-up unbounded	At most 500 live demo accounts; clean-up of 50 per tap, never blocking	`worker/hardening.test.ts`
12	IPv6 clients could rotate addresses past network limits; no service-wide Ask cap	IPv6 limited per /64 network; Ask capped at 3,000 questions a day for the service	`worker/hardening.test.ts`
13	Refused posts still used the shared moderation model without counting	Every post attempt counts before moderation (20 per 10 minutes)	Inspection (inside the group-room Durable Object)
14	One account could open many sockets to a room	At most three sockets per account per room; `/live` rate-limited	Inspection (inside the group-room Durable Object)
15	A shared `#/ask/<question>` link sent the question and spent the student's allowance	The link only fills the question box	Inspection (client)
16	Disguised phone numbers and emails, and chat-invite links, passed the group contact filter (D-04)	Filter also runs on a normalised copy	`worker/groups.e2e.test.ts` (GRP-012 to GRP-016)
17	Developer tools of Ask lacked a cross-site check	Refuse a cross-site call even on localhost	`worker/hardening.test.ts`
Other	The email pattern ran before the length check on very long input	Length checked first	`worker/hardening.test.ts`

All leads except lead 9 are fixed. Fixes after 59ad7760 go live with the next deploy, after the product owner's GO, and their live check is logged in `WORKLOG.md`. Because no lead was proven by exploitation, the audit should be repeated on a separate staging environment once one exists.

5 Limits of this campaign

- **Production writes were not exercised.** Automated runs that create data on the live service were blocked by the tooling's safety checks; the live service was tested read-only (124 cases). Write paths were tested on the local Worker with the same code and migrations, and after each deploy a manual live check is logged in WORKLOG.
- **Ask ZedPath against the real model** was not run (quota); the logic around the model was tested offline.
- **Traceability:** 69.6 % of the 224 active requirements have at least one test (47.8 % directly); the uncovered ones are listed with a suggested test in tools/e2e/results/traceability.md.
- No usability study with students and no native-speaker review of Sinhala and Tamil in this campaign.

6 Conclusion

The release is fit for the demonstration: the core promise (the right courses, from the official data, with a source for every number, enforced on the server) passed every accuracy, API, database and browser test. The open defects are presentation, hardening and performance items; D-01, D-02, D-04 and D-06 are recommended before a public launch. *Update (15 October 2026):* D-03, D-04, D-05, D-10 and D-12 are fixed and the http link of D-08 is fixed; D-01, D-02 and D-06 remain recommended before a public launch, and security audit run-1 left one accepted risk (lead 9).

7 Appendix A. Result files

All result files are in tools/e2e/results/ in the repository, each with the test code that produced it: api-results, ui-results, security, groups, pwa, a11y-i18n, responsive, live-readonly, live-static, accuracy, migrations, data-integrity, journey-logic, list-compare, ask, perf and traceability.